

Thông tin nhóm & phân công nhiệm vụ

- Nhóm: 07
- Học phần: Kiến trúc hướng dịch vụ (SOA) / Thiết kế REST API
- Bảng phân công chi tiết:

STT	Thành viên	Nhiệm vụ đảm nhiệm
1	Phạm Tuấn Phong	Tiêu chí 1, 2, 3 (Resource Naming, Conventions, HTTP Status Codes)
2	Tạ Đình Nguyên	Tiêu chí 4, 5 (Idempotency, Error Response RFC 7807/9457)
3	Nguyễn Quốc Phong	Tiêu chí 6, 7 (Pagination Strategies, Filtering & Sorting)
4	Trần Đức Mạnh	Tiêu chí 8, 9 (Authentication & Security, Versioning & Deprecation)

Nội Dung Đánh Giá Chi Tiết Theo 9 Tiêu Chí

1. Tài nguyên là danh từ

- Điểm cộng:
 - Các endpoint dữ liệu tuân thủ chuẩn danh từ số nhiều: `/albums`, `/tracks`, `/playlists/{id}`.
 - Các phương thức HTTP (`GET`, `POST`, `PUT`, `DELETE`) được dùng đúng ngữ nghĩa thao tác trên tài nguyên.
- Điểm trừ:
 - Nhóm endpoint điều khiển phát nhạc (Player) lạm dụng động từ trong URI: `/me/player/play`, `/me/player/pause`, `/me/player/next`. Bản chất các thao tác này là gửi lệnh điều khiển (RPC-style) thay vì thao tác trên thực thể dữ liệu.

2. Naming nhất quán

- Điểm cộng:
 - Đường dẫn (path) viết thường toàn bộ (lowercase), collection dùng số nhiều: `/albums`, `/tracks`, `/shows`, `/episodes`.
 - Tham số truy vấn (query) và thuộc tính JSON payload đều sử dụng định dạng `snake_case`: `device_id`, `include_external_additional_types`, `release_date`, `external_urls`.
 - Tính đồng nhất cao ở cấu trúc đối tượng: mọi resource đều chứa bộ 4 thuộc tính cơ bản `id`, `uri`, `href`, `type`.
- Điểm trừ:
 - Tồn tại song song cả `id` và `uri` cho cùng một tài nguyên, gây nhầm lẫn khi truyền tham số giữa các endpoint khác nhau.
 - Thay đổi tên trường thiếu triệt để: tài nguyên playlist có cả `tracks` và `items`; endpoint `/playlists/{id}/tracks` bị thay bằng `/items` nhưng cả hai vẫn cùng tồn tại, dễ gây nhầm lẫn khi tích hợp.

3. Status code đúng nghĩa

- Điểm cộng:
 - Sử dụng chuẩn xác các mã trạng thái phổ biến: `200 OK`, `201 Created`, `204 No Content` (cho các lệnh Player thực thi thành công), `304 Not Modified`, `429 Too Many Requests`.
 - Hỗ trợ cơ chế caching qua header `ETag` và phản hồi `304 Not Modified`.
 - Quá tải hệ thống trả về mã `429` kèm header điều hướng `Retry-After`.
- Điểm trừ:

- Mã `403 Forbidden` bị quá tải ngữ nghĩa: dùng chung cho nhiều nguyên nhân khác nhau (thiếu OAuth scope, tài khoản không có Spotify Premium, tài khoản chưa được thêm vào allowlist ở chế độ development mode, endpoint bị hạn chế theo vùng), khiến client khó phân nhánh xử lý tự động.
- Thiếu mã lỗi chuyên biệt: endpoint `PUT /me/player/play` chỉ liệt kê `204`, `401`, `403`, `429`, không có status code đặc thù khi không tìm thấy thiết bị phát (Active Device).

4. Idempotency rõ ràng

- Điểm cộng:
 - Các phương thức cập nhật toàn phần và xoá (`PUT`, `DELETE`) đảm bảo tính idempotent theo chuẩn HTTP.
 - Tài nguyên Playlist sử dụng cơ chế khóa phiên bản `snapshot_id` giúp phát hiện xung đột và tránh ghi đè nhầm trạng thái dữ liệu.
- Điểm trừ:
 - Thiếu cơ chế header `Idempotency-Key` (như Stripe/IETF draft) cho phương thức `POST`. Khi client tự động retry do gián đoạn mạng, nguy cơ cao phát sinh trùng lặp bản ghi (tạo lặp playlist hoặc thêm bài hát 2 lần).
 - Thứ tự thực thi chuỗi lệnh điều khiển Player khi có network retry không được cam kết đồng bộ.

5. Error response có cấu trúc

- Điểm cộng:
 - Phản hồi lỗi API thông thường có cấu trúc thống nhất: `{"error": {"status": ..., "message": "..."} }`, trong đó giá trị `status` đồng bộ với HTTP status code.
 - Phân hệ xác thực tuân thủ RFC 6749; hỗ trợ trường `reason` dạng enum (ví dụ: `QUOTA_EXCEEDED`).
- Điểm trừ:
 - Chưa áp dụng định dạng chuẩn RFC 7807 / RFC 9457 (`application/problem+json`): thiếu các trường định danh chuẩn như `type`, `title`, `detail`, `instance`.
 - Trường `reason` không bắt buộc (optional), khiến client phải bóc tách chuỗi `message` để bắt lỗi cụ thể, dễ gây ứng dụng khi API thay đổi câu chữ.
 - Tồn tại 2 định dạng lỗi song song giữa luồng OAuth và luồng API Core, buộc client phải cài đặt hai parser riêng biệt.

6. Pagination rõ ràng

- Điểm cộng:
 - Mọi danh sách trả về đều dùng chung schema phân trang: `href`, `limit`, `offset`, `total`, `next`, `previous`, `items`.
 - Các trường `next` và `previous` cung cấp URL đầy đủ (hoặc `null`), giúp client duyệt trang trực tiếp mà không cần tự tính toán offset.
 - Đặt giới hạn trên (max limit) chặt chẽ cho từng collection (ví dụ: Search mặc định 5, tối đa 10, offset trần 1000; Playlist items mặc định 20, tối đa 50).
- Điểm trừ:
 - Phân trang chủ yếu dựa trên Offset-based: dễ xảy ra hiện tượng lệch/trùng dữ liệu nếu danh sách có bài hát mới được thêm/xoá giữa hai lần gọi liên tiếp.
 - Không đồng nhất phương pháp: một số endpoint đặc thù dùng cursor pagination, buộc client phải xử lý hai cơ chế duyệt khác nhau.
 - Giới hạn `limit` và `offset` tối đa không nhất quán giữa các tài nguyên và không được quy định tập trung trong tài liệu tổng quát.

7. Filter/Sort đa dạng

- Điểm cộng:
 - Endpoint Search hỗ trợ lọc theo trường cụ thể (`artist`, `year`, `genre` ...) và cho phép tìm kiếm đa loại tài nguyên cùng lúc qua query parameter `type`.
 - Hỗ trợ trích xuất trường dữ liệu cụ thể (Sparse Fieldsets) qua tham số `fields` trên endpoint Playlist, cho phép lọc lồng nhau và loại trừ trường.

- Điểm trừ:
 - Cú pháp lọc của Search bị gộp vào chuỗi truy vấn `q` (ví dụ: `q=artist:ab&type=album`), gây khó khăn trong khâu validate đầu vào và dễ gặp lỗi encode ký tự đặc biệt.
 - Hầu như không hỗ trợ tham số sắp xếp (`sort` / `direction`), buộc ứng dụng client phải kéo toàn bộ dữ liệu về để tự xử lý trên bộ nhớ.
 - Tính năng `fields` chỉ được triển khai cục bộ ở một số ít endpoint, chưa phủ rộng toàn hệ thống.

8. Authentication và Security

- Điểm cộng:
 - Sử dụng chuẩn OAuth 2.0 toàn diện với 3 luồng: Authorization Code, Authorization Code kèm PKCE, và Client Credentials.
 - Hệ thống phân quyền chi tiết (fine-grained scopes), tuân thủ nguyên tắc đặc quyền tối thiểu (Principle of Least Privilege).
 - Loại bỏ hoàn toàn luồng Implicit Grant để tránh nguy cơ Access Token trực tiếp trên URL / trình duyệt.
 - Cơ chế Rate Limiting tính theo cửa sổ trượt 30 giây kèm phản hồi `Retry-After`.
- Điểm trừ:
 - Không công bố công khai hạn mức cụ thể của Rate Limit, lập trình viên chỉ biết giới hạn khi nhận mã lỗi 429.
 - Chính sách kiểm soát môi trường phát triển (Development Mode) quá khắt khe: giới hạn tối đa 5 tài khoản thử nghiệm và yêu cầu chủ sở hữu phải có gói Premium; Extended Mode chỉ xét duyệt cho tổ chức đạt từ 250.000 MAU.

9. Versioning + Deprecation

- Điểm cộng:
 - Áp dụng tiền tố phiên bản URI ngay từ đầu (`/v1`).
 - Các trường và endpoint chuẩn bị gỡ bỏ đều được đánh dấu nhãn `Deprecated` kèm tài liệu chỉ dẫn endpoint thay thế.
 - Cung cấp trang Changelog định kỳ hàng tháng và Migration Guide có mốc thời gian rõ ràng.
- Điểm trừ:
 - Vi phạm tính ổn định của `/v1`: Spotify thường xuyên gỡ bỏ tính năng hoặc thay đổi schema trực tiếp ngay trong nhánh `v1` (các đợt lớn vào 11/2024 và đầu 2026), làm mất đi bản chất bất biến của versioning.
 - Chế độ Dev Mode và Extended Mode ghi nhận hành vi khác nhau trên cùng một version endpoint.
 - Vòng đời deprecation quá ngắn đối với ứng dụng ở chế độ dev mode (thường chỉ thông báo trước khoảng 1 tháng); một số thay đổi đột ngột bị hoàn tác (như thay đổi liên quan đến `available_markets`), gây gián đoạn lớn cho các bên tích hợp.

Đánh Giá Chung

Spotify Web API sở hữu nền tảng thiết kế RESTful tương đối vững chắc: quy ước đặt tên (naming conventions) có tính hệ thống cao, sử dụng HTTP semantics chính xác, cơ chế xác thực an toàn qua OAuth 2.